



HACKTHEBOX

Meetup Zurich, CH

<https://htbzh.ch/>



Antoine Neuenschwander
Tech Lead Bug Bounty Program
Swisscom

Admin



Wi-Fi



Nearest Restrooms



Consent for Pictures

Hosts

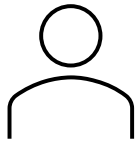


Antoine Neuenschwander
Tech Lead Bug Bounty
Swisscom



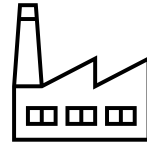
HACKTHEBOX

> 400 virtual machines (boxes)



HTB Labs

<https://app.hackthebox.com>



HTB Enterprise Platform

<https://enterprise.hackthebox.com>

Hacker Glossary

To Pwn

To fully compromise a system. Typo of *own*. Originates from video game culture.

Noteworthy references:

- ***Have I Been Pwned***, data breach search and notification service
- ***Pwn2own***, computer hacking contest
- ***Pwnie Awards***, annual awards ceremony that recognizes both excellence and incompetence in the field of information security

Capture the Flag (CTF)

A computer security competition where solving a challenge yields a flag string you submit for points. Originates from military exercises.

Red / Blue Team

Offensive side (adversary simulation) / Defensive side (hardening, detection, response). Originates from military exercises.

1337 / leet

Elite, written in leetspeak, where l3tt3r5 4r3 5w4pp3d f0r l00k4l1k3 d1g1t5. Originates from the Bulletin Board Systems (BBS) slang of the 80s.

Foothold

Initial access to the target machine, achieved via remote/arbitrary code execution, typically as a low-privileged user. Provides access to the user .txt flag.

Privesc

Privilege escalation. Going from a low-privileged user to root (unix/linux) or SYSTEM (Windows). Provides access to the root .txt flag.



Offensive Security

aka Ethical Hacking / White Hat Hacking

Understand Technology
Acknowledge there is no 100% security
Find Vulnerabilities

Contradict all Assumptions



Legal Aspects

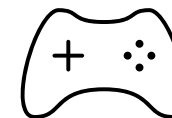
Computer hacking is illegal, right?

Art. 143 bis Swiss Penal Code

Unauthorized access to a data processing system

Hack The Box

Provides lab environment to learn about attacker tactics



Gamification

Capture the Flag (CTF)
Hacking Competition

(warning: addictive)



Registration

<https://htbzh.ch/onboarding.html>

A Platform Invitation

Provide your email address to receive an invitation link



Follow the invitation link, if needed, register a new HTB account

B Lab Onboarding

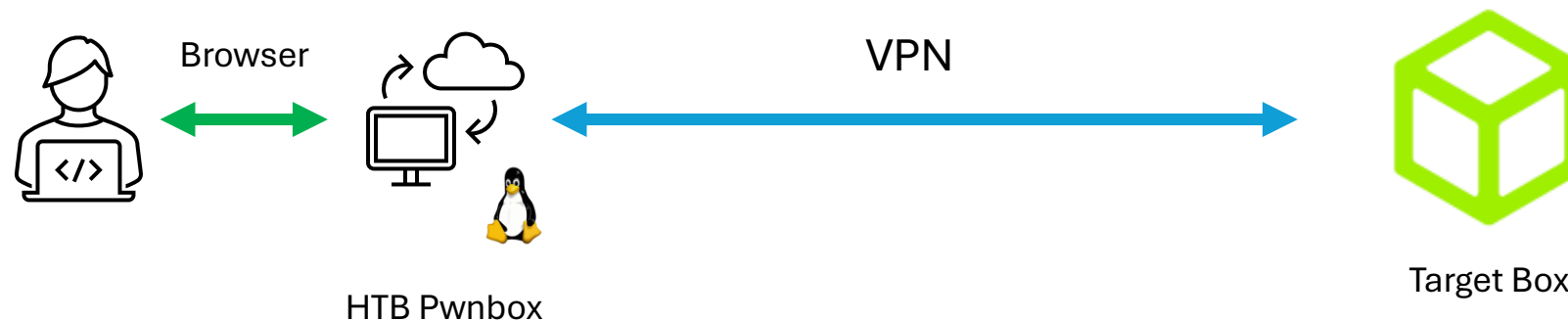
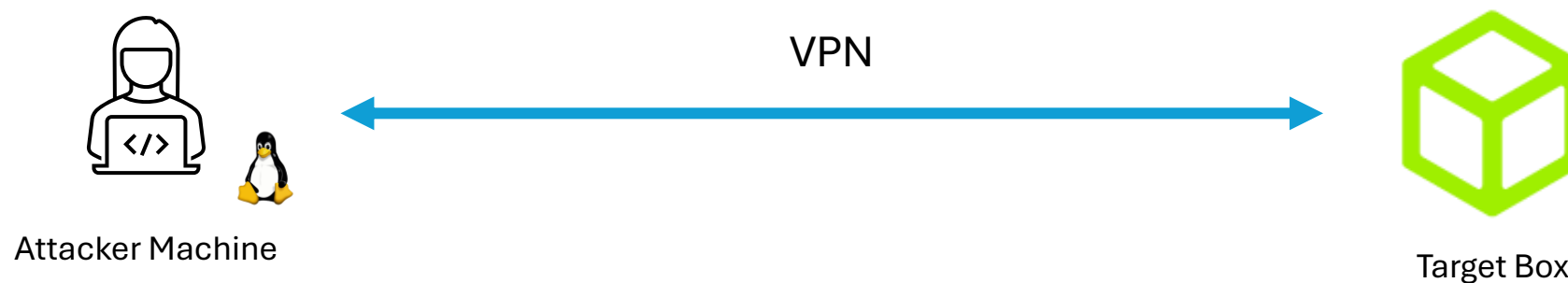
Provide your email address (again) to gain access to the lab

<https://enterprise.hackthebox.com>

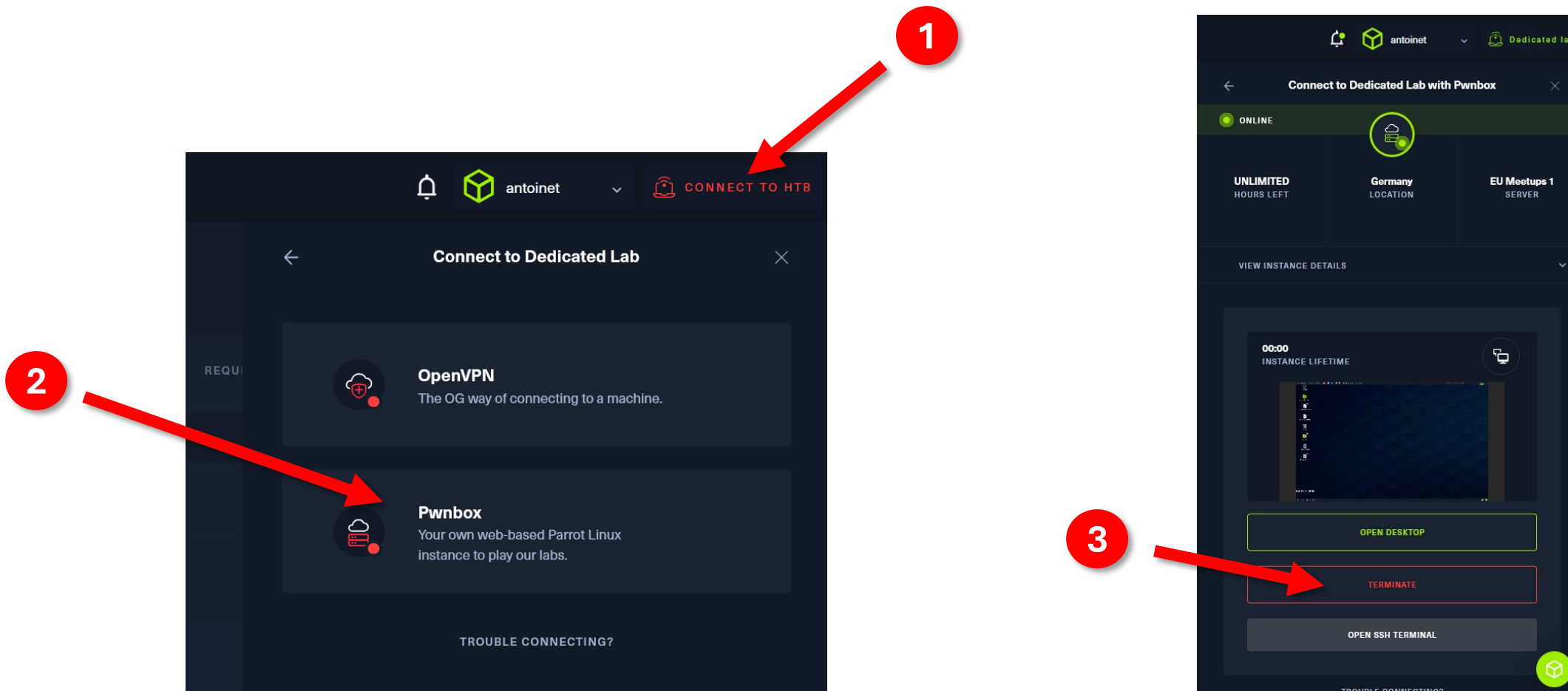


Meetup Lab

Hacking Setup



Start and Connect to your Pwnbox



The image shows two screenshots of the Antoinet mobile application interface, illustrating the steps to connect to a Pwnbox.

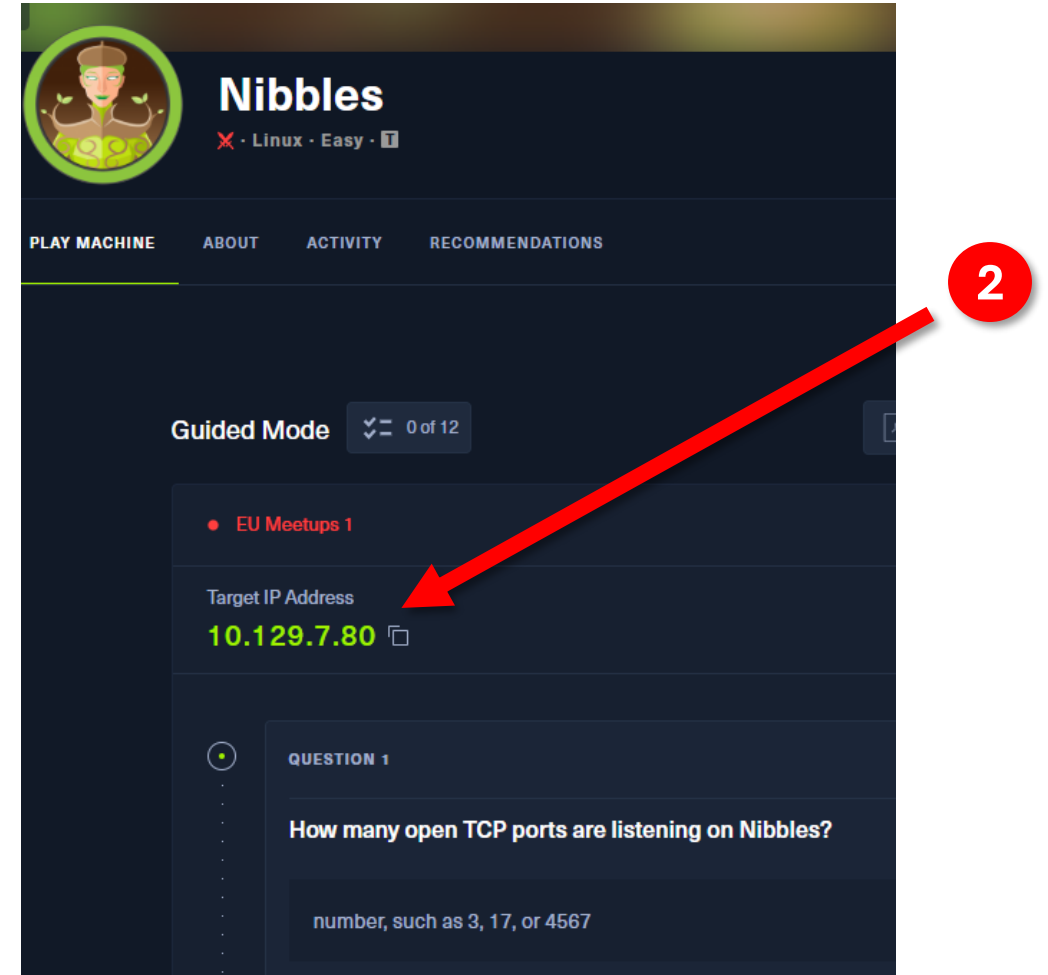
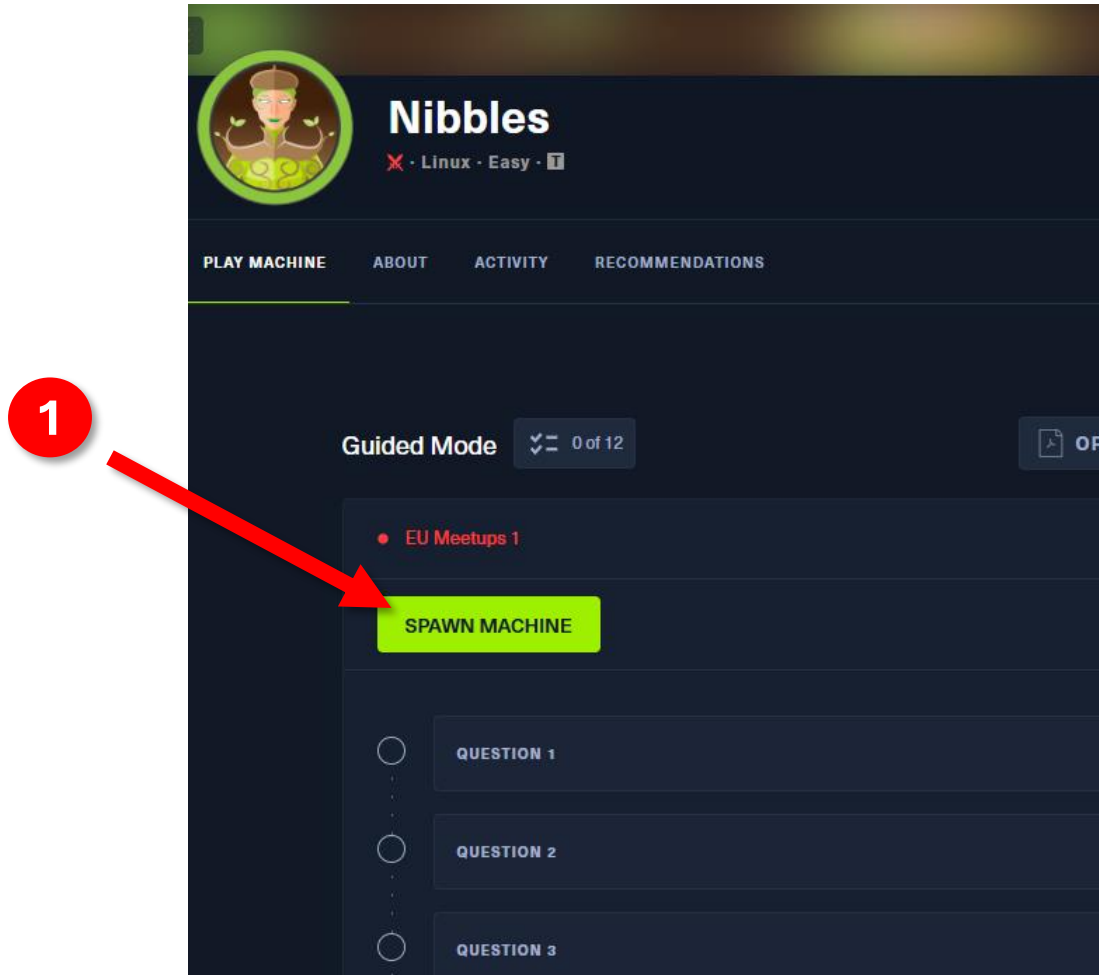
Step 1: The first screenshot shows the main menu with the "CONNECT TO HTB" button highlighted by a red arrow labeled "1".

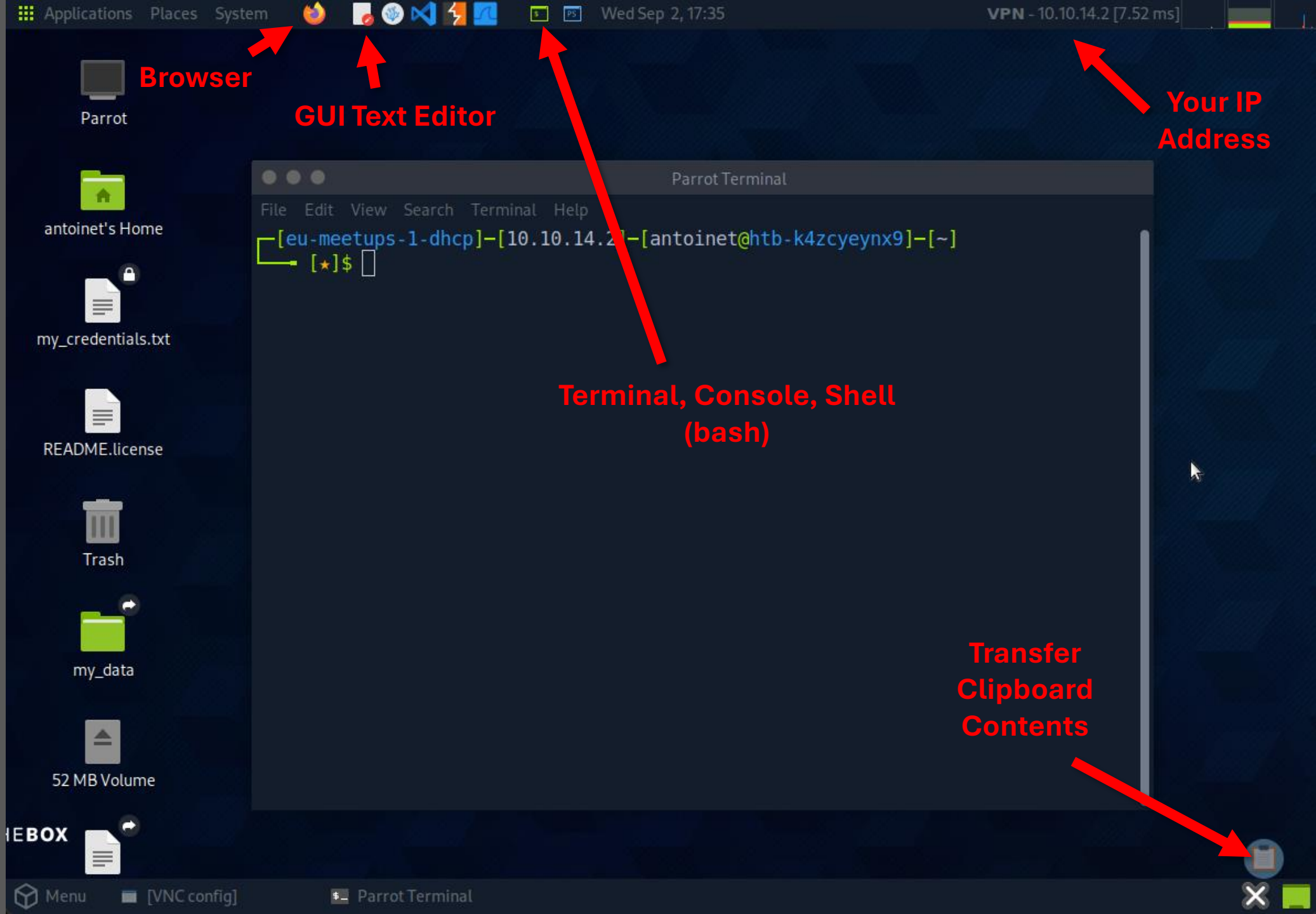
Step 2: The second screenshot shows the "Connect to Dedicated Lab" screen. The "Pwnbox" option is highlighted by a red arrow labeled "2".

Step 3: The third screenshot shows the "Connect to Dedicated Lab with Pwnbox" screen. The "TERMINATE" button is highlighted by a red arrow labeled "3".

https://help.hackthebox.com/en/articles/5185687-introduction-to-lab-access#h_9b6b4f1e1a

Spawn the Target Box





Hacking / Walkthrough



Initial Situation

- Website of a courier service in Zurich
- Set up by a freelancer in 2019
- No maintenance since

Find vulnerabilities and exploit them!

▲ Übungsumgebung — absichtlich verwundbare Demo-Website für den Workshop «Hacken erlaubt». VeloRapid Zürich GmbH ist ein fiktives Unternehmen, alle Daten sind erfunden.

VeloRapid
VELOKURIER ZÜRICH

[Home](#) [Leistungen](#) [Preise](#) [Über uns](#) [Kontakt](#)

Same-Day-Kurier für Zürich – seit 2014 im Sattel.

Dokumente, Laborproben, Ersatzteile: Wir holen ab und stellen zu – emissionsfrei, innerhalb der Stadt in der Regel unter 60 Minuten.

[Auftrag erteilen](#) [Preise ansehen](#)

Express innert 60 Min.

Direktfahrt ohne Zwischenstopp im Stadtgebiet Zürich.

Laborlogistik

Begleitete Transporte für Praxen und Labors, 7 Tage die Woche.

Fixe Touren

Wiederkehrende Abholungen zu fixen Zeiten – zum Monatspauschalpreis.

Lastenvelo

Sendungen bis 80 kg und 120 × 60 × 60 cm, ohne Lieferwagen.

Warum VeloRapid?

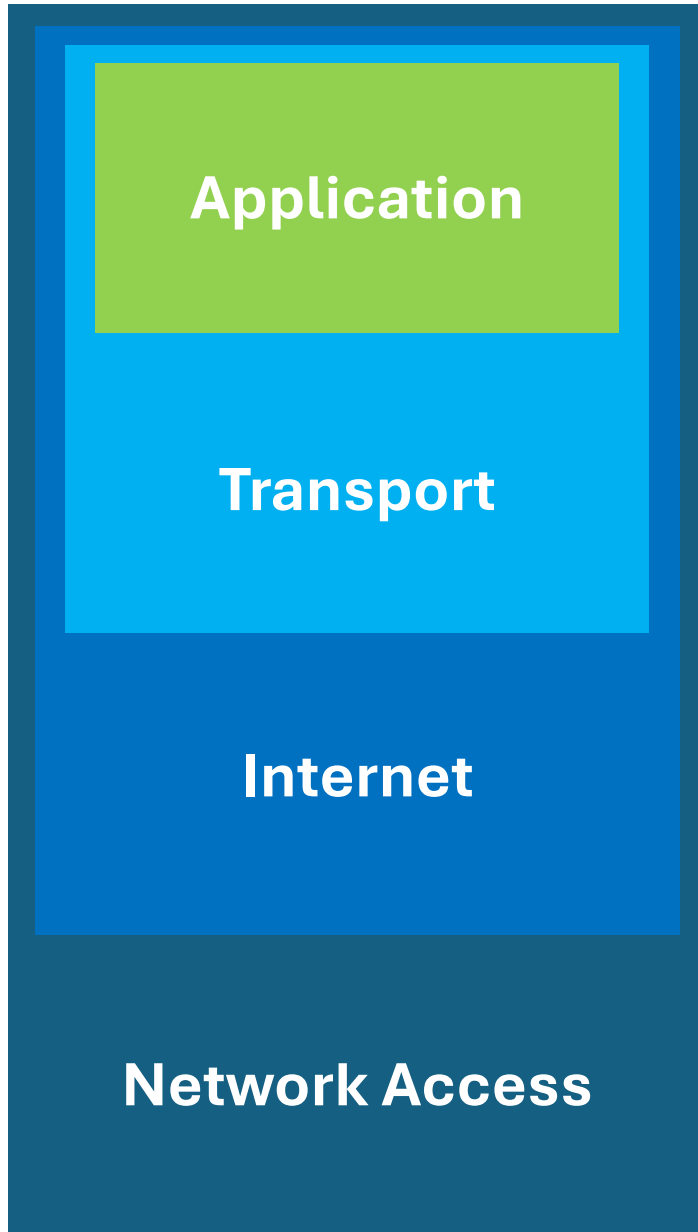
28 Kurierinnen und Kuriere, ein eigenes Dispositionsteam und kein einziger Verbrennungsmotor. Unsere Disposition sitzt in Zürich-West und ist von 06:30 bis 20:00 Uhr besetzt.

Kennzahl	2018	2019
Zugestellte Sendungen	41 200	52 870

A close-up photograph of a network switch or patch panel. Numerous white Ethernet cables are plugged into the ports. Some cables have yellow or blue RJ45 connectors. Several ports have small green LEDs lit, indicating active connections. A small white label with black text is visible on one of the cables, reading "From: M" and "To: DIS".

Assignment 1

Network Reconnaissance



Provides **network services** to applications

HTTP, FTP, SMTP, SSH, etc.



Letter content, e.g. Invoice, postcard

Ensures **reliable data transfer** between devices

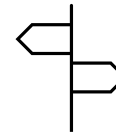
TCP Port 1337



Apartment number

Routing of data packets within and between networks

IPv4 Address 203.0.113.45

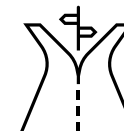


Postal address

Physical Transmission of Data

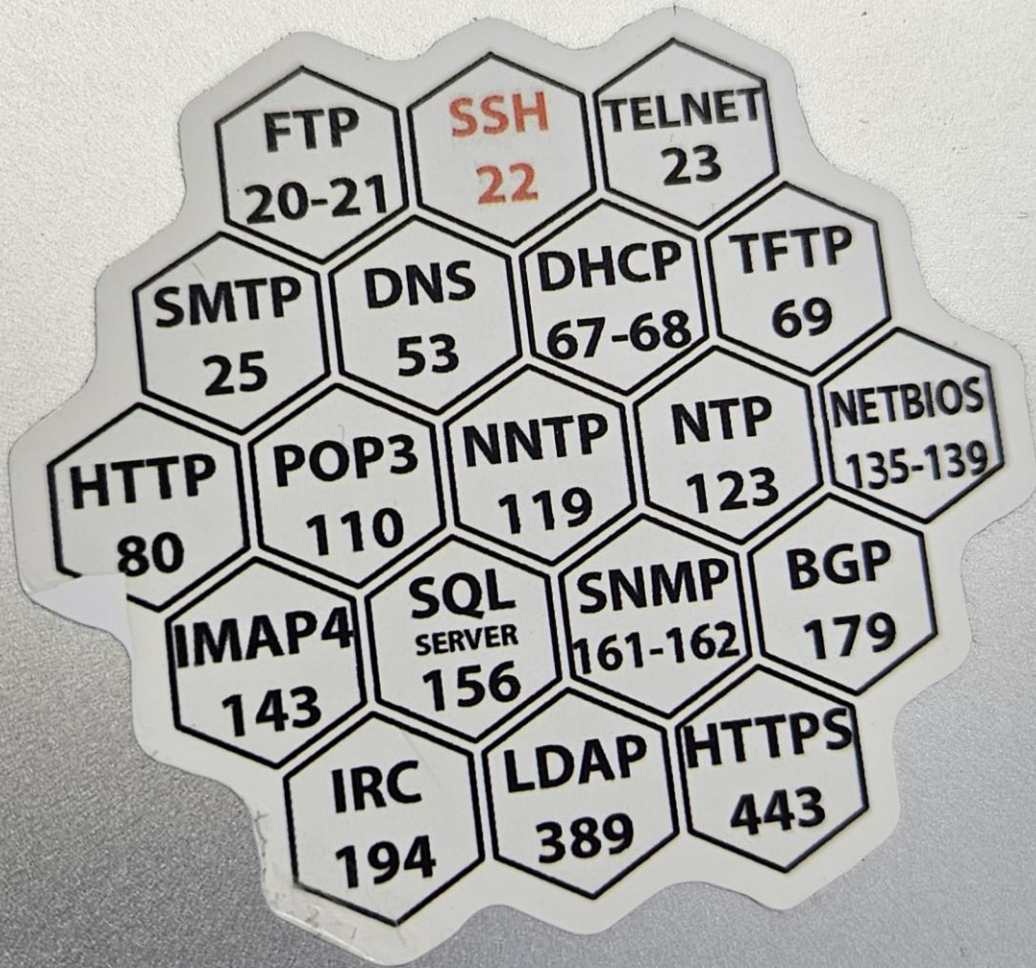
- Ethernet (LAN cable)
- Wi-Fi

MAC Address 48:2C:6A:1E:59:3F



Road + post truck

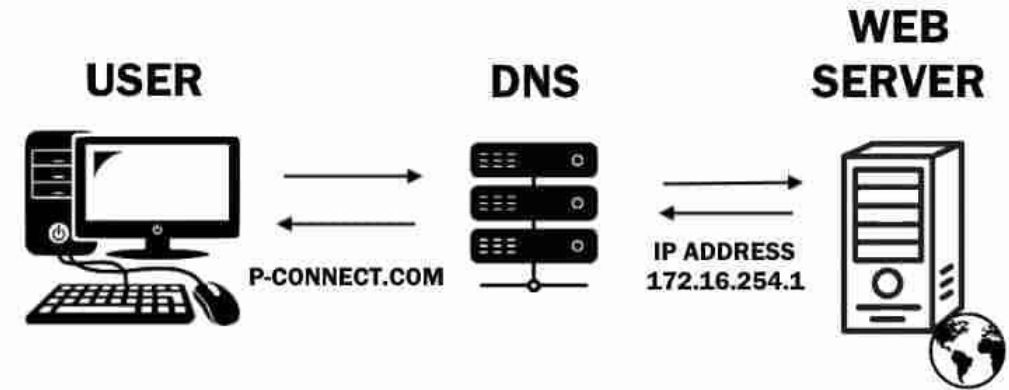
Default / Standard TCP Port Mappings



- Ports (0–65535) let one IP address run multiple network services simultaneously
- Ports 0–1023 are "well-known ports," reserved by IANA and mapped to standard services
- Recognizing these mappings helps analysts interpret scans and spot suspicious activity on unexpected ports

Domain Name System

- DNS (Domain Name System) translates human-readable domain names into IP addresses
- Computers need IP addresses to communicate; DNS spares humans from having to memorize them



nmap the network mapper

Basic usage

Target = hostname or IP address

```
$ nmap <target>
```

Port specification

Scan specific ports

```
$ nmap -p21,22,80-99 <target>
```

Scan all ports

```
$ nmap -p- <target>
```

Timing options

Minimal rate (packets/sec)

```
$ nmap --min-rate=1000 <target>
```

Timing templates (0-5, higher is faster)

```
$ nmap -T4 <target>
```

Version Scanning

Determining service/version information

```
$ nmap -sV <target>
```

Script Scanning

Run nmap default scripts

```
$ nmap -sC <target>
```

nc netcat - connecting to ports

Basic usage

Target = hostname or IP address

```
$ nc <target> <port>
```

Example

```
$ nc google.ch 80
```

```
asfd
HTTP/1.0 400 Bad Request
Content-Type: text/html; charset=UTF-8
Referrer-Policy: no-referrer
Content-Length: 1555
Date: Sun, 20 Sep 2026 10:21:46 GMT
```



Target IP Address

139.59.135.155

velorapid-zuerich.lab.htbzh.ch





Assignment 2

Identify hidden endpoints

The background of the slide is a close-up, high-contrast image of a fingerprint. The ridges and valleys are clearly visible, creating a complex, wavy pattern. Overlaid on the right side of the fingerprint is a bright orange crosshair, consisting of a vertical line and a horizontal line intersecting at a point. The overall color scheme is dark, with the fingerprint appearing in shades of blue, grey, and white against a black background.

Well-Known Files

- Web applications often expose standard files at predictable paths
- These files can reveal site structure, configuration details, or unintentionally exposed secrets
- Checking for them is a quick, low-effort step in reconnaissance

robots.txt	Tells search engine crawlers which parts to avoid/allow
sitemap.xml	Lists site pages for search engine indexing
favicon.ico	The small browser icon
.well-known/security.txt	Contact information for reporting security vulnerabilities

Fuzzing // Forceful Browsing // URL Brute-Forcing

Why?

- Web server pages are served and reachable, regardless if linked to or not
- Examples of unlinked resource:
 - Admin panels
 - Backup directories
 - Credentials in .env files, or source code in .git/ repositories
- Obscurity is the only thing protecting them

How?

- Use a wordlist of known, common filenames/paths
- Such wordlists are readily available online (search for “seclists”)
- Use a “fuzzer” tool to query the webserver
- Win

gobuster directory/file busting tool

```
$ gobuster dir -u <target-url> -w <wordlist> -t <num-threads> -x <exts>
```

Directory brute-
forcing mode

Target URL

http://<ip-address>:<port>

Path to
wordlist file

Pwnbox wordlists are
located at
/usr/share/wordlists/

Number of
concurrent threads
(default 10)

You might want to
crank that up if
you're impatient

File extensions to
search for

For example:
php,txt

HTTP Status Code	Bedeutung
200	Ressource existiert und wird zurückgegeben
301, 302	Weiterleitung auf eine andere Ressource
403	Existiert, aber Zugriff verweigert
404	Nicht vorhanden

Assignment 3

Sign-In Backend User





VeloRapid Dispo-Portal

Interner Bereich – nur für Mitarbeitende der Disposition.

Benutzername

Passwort

Anmelden

Zugang vergessen? Die Disposition erreichst du unter
044 000 00 00.

Systemhinweis: Die Anmeldung erfolgt mit dem Datenbank-
Service-Account (siehe Konfigurationsdatei der Website).

Übersicht

Aufträge

Kunden

Datenbank

Datenbank

velorapid_dispo

Service-Account `dispo_ro` – Lesezugriff auf alle Tabellen.

Tabelle	Zeilen	Spalten	
kunden	8	9	<button>durchsuchen</button>
auftraege	9	9	<button>durchsuchen</button>
mitarbeiter	5	7	<button>durchsuchen</button>

SELECT * FROM `mitarbeiter`Passwörter werden als MD5-Hash gespeichert (Legacy-Schema von 2014). [Hashes exportieren](#)

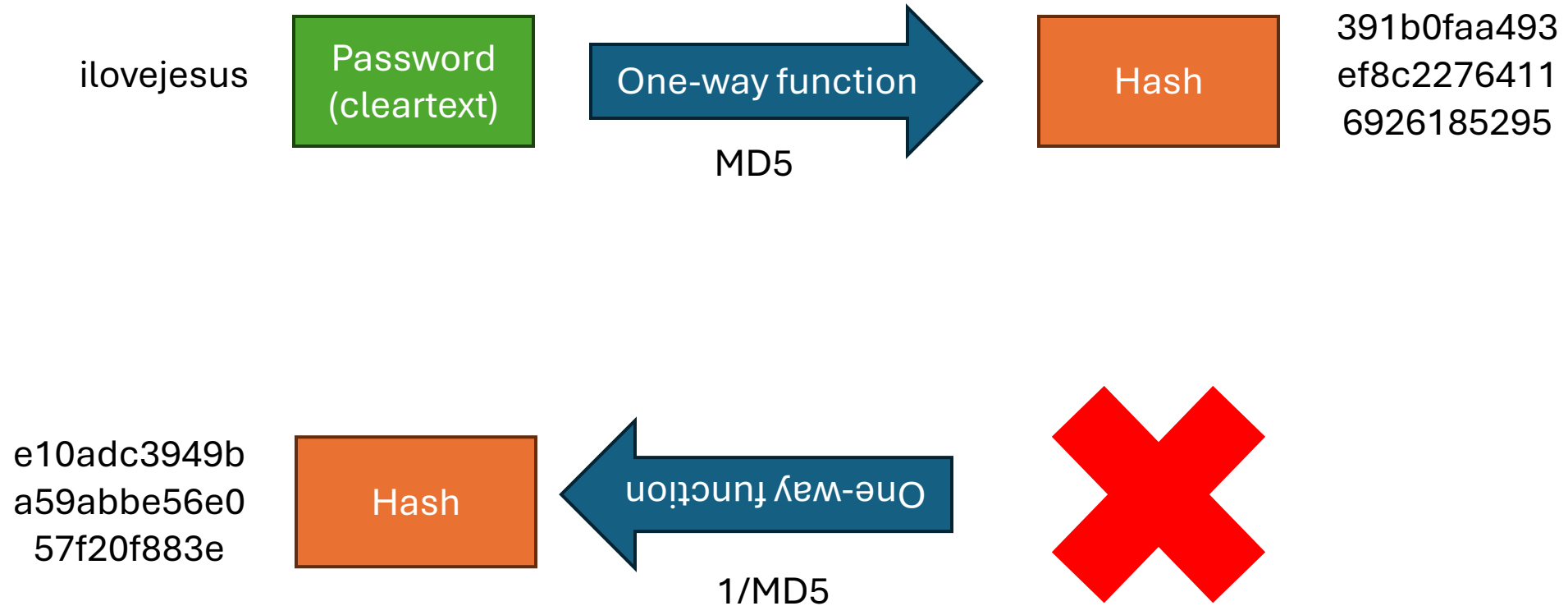
id	benutzername	name	rolle	email	passwort_md5	letzter_login
1	s.brunner	Sandra Brunner	admin	s.brunner@velorapid.example	5fcfd41e547a12215b173ff47fdd3739	2019-11-04 08:12:41
2	m.keller	Marco Keller	disponent	m.keller@velorapid.example	0571749e2ac330a7455809c6b0e7af90	2019-11-04 07:55:02
3	l.fischer	Luca Fischer	kurier	l.fischer@velorapid.example	0d107d09f5bbe40cade3de5c71e9e9b7	2019-11-03 18:40:17
4	a.moser	Anja Moser	buchhaltung	a.moser@velorapid.example	8afa847f50a716e64932d995c8e7435a	2019-10-31 16:22:58
5	dispo_ro	Service-Account Dispo (read-only)	service	it@velorapid.example	4152e75ef42d9dcd99153295d130f220	2026-09-18 03:00:11

The background of the slide features a close-up, low-key photograph of a metallic combination lock with three visible dials. The dials are set against a dark, blurred background that includes a green printed circuit board (PCB) with various electronic components like resistors and capacitors. The lighting is dramatic, highlighting the metallic textures of the lock and the intricate details of the circuitry.

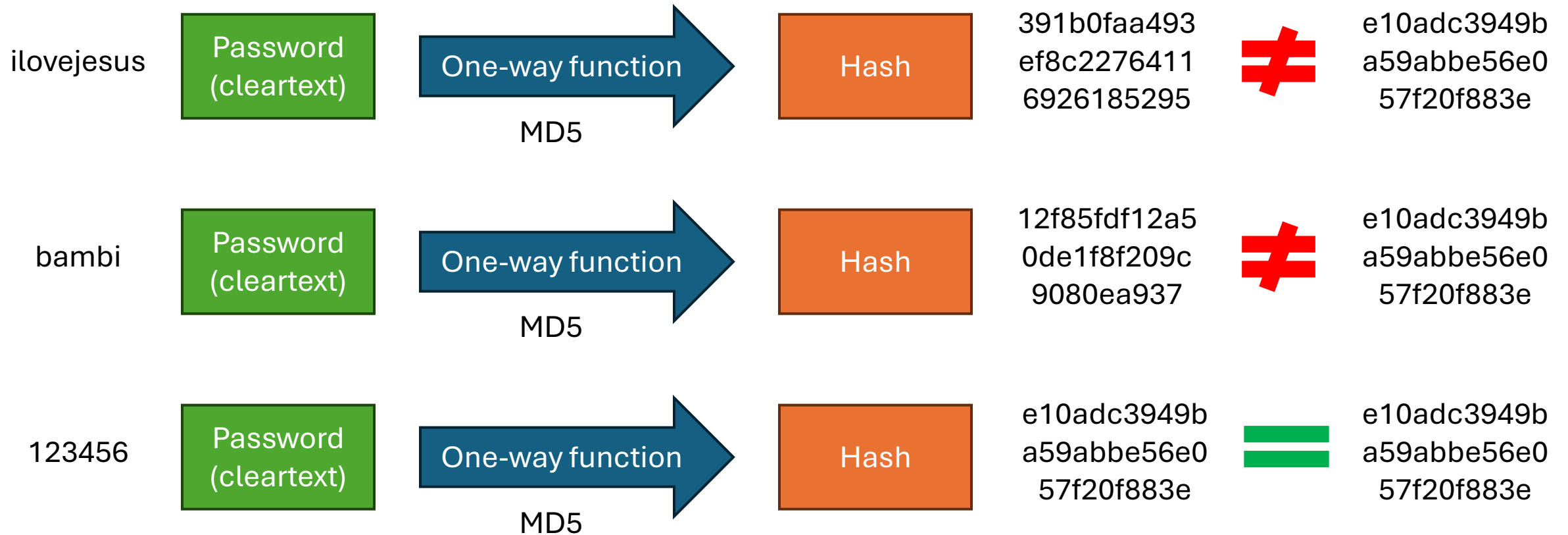
Assignment 4

Password Cracking

Password Cracking 101



Password Cracking 101



hashcat

```
$ hashcat -m 0 -a 0 --username velorapid_hashes.txt <wordlist>
```

Hash algorithm

0 = MD5

Attack mode

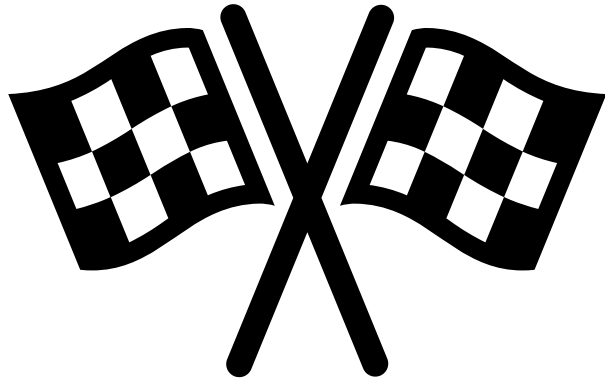
0 = bruteforce

Hash file in format
<username>:<hash>

Hash file

(pass)word list

/usr/share/wordlists/rockyou.txt.gz



Thanks for your
Participation !
You did Awesome !!!



HACKTHEBOX

Meetup Zurich, CH

<https://htbzh.ch/>